ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

KIỂM CHỨNG NGƯỠNG CVSS 8,0 CỦA CSA VÀ ĐỀ XUẤT CÔNG THỨC ƯU TIÊN VÁ LỖ HỔNG

Kết hợp CVSS, EPSS, CISA KEV và Chỉ thị BOD 26-04

Học phần Chính sách và Quản trị an ninh mạng, Nhóm 14

Giảng viên: TS. Nguyễn Đức Toàn, TS. Lê Xuân Thành

Trần Minh Vương : 20252023M

Vũ Thành Huy : 20252033M

Nguyễn Hoà Khiêm : 20252031M

ONE LOVE. ONE FUTURE.

Ngưỡng CVSS 8,0 vá thừa và bỏ sót; công thức S dồn nguồn lực đúng chỗ hơn

98,69%

lỗ hổng phải vá trong 48 giờ chưa từng bị khai thác (65.845 / 66.722)

44,14%

lỗ hổng đã bị khai thác bị bỏ qua vì CVSS dưới 8,0 (693 / 1.570)

28 lần

mức S từ 70 có tỷ lệ bị khai thác cao gấp khoảng 28 lần trung bình

1	**Đề xuất**	Điểm S kết hợp CVSS, EPSS, KEV, hai biến của BOD 26-04 (tự động hóa, phơi ra Internet) và mức quan trọng tài sản
2	**Kiểm chứng**	Kiểm thử ngược tại 11 ngày đánh giá, chỉ dùng thông tin có tại ngày đó
3	**Kết quả**	Khi vá ít, S bắt được nhiều gấp 2,7 đến 8,9 lần xếp theo CVSS; ngang EPSS dùng riêng
4	**Giới hạn**	Chưa cảnh báo trước được lỗ hổng mới công bố; hệ số tài sản chưa kiểm chứng được

LLM rút ngắn thời gian khai thác, nên CSA đề xuất vá trong 48 giờ theo CVSS

BẰNG CHỨNG BÀI BÁO CSA DẪN

87% và 7% — GPT-4 khai thác 87% trong 15 lỗ hổng một ngày khi có mô tả CVE, chỉ 7% khi không có

86% — Hệ thống tại DARPA AIxCC 2025 tìm ra 86% lỗ hổng tổng hợp và 18 lỗ hổng thật

37 / 40 — Incalmo tự động chiếm tài sản quan trọng ở 37 trên 40 môi trường mô phỏng

KHUYẾN NGHỊ CẦN KIỂM CHỨNG

CVE có CVSS trên 8,0 ảnh hưởng tới hệ thống phơi ra Internet phải được vá trong vòng 48 giờ

Nguồn: CSA, Automated Exploit Generation: LLMs Cross the Threshold, 02/04/2026, trang 14

VẤN ĐỀ

CVSS đo hậu quả nếu bị khai thác, không đo lỗ hổng có đang bị khai thác hay không. Một ngưỡng CVSS cố định có thể vá sai chỗ: đây là điều nhóm kiểm chứng trên dữ liệu thật.

Nhóm kiểm chứng trên 240.409 lỗ hổng bằng ba nguồn dữ liệu công khai

NGUỒN DỮ LIỆU

NVD (NIST)

Điểm CVSS 3.x của 240.409 lỗ hổng, mã CVE từ 1999 đến 2025

CISA KEV

1.570 lỗ hổng đã được xác nhận bị khai thác trong phạm vi; phiên bản 2026.10.08

FIRST EPSS

Xác suất bị khai thác trong 30 ngày tới; dùng điểm lịch sử theo từng ngày

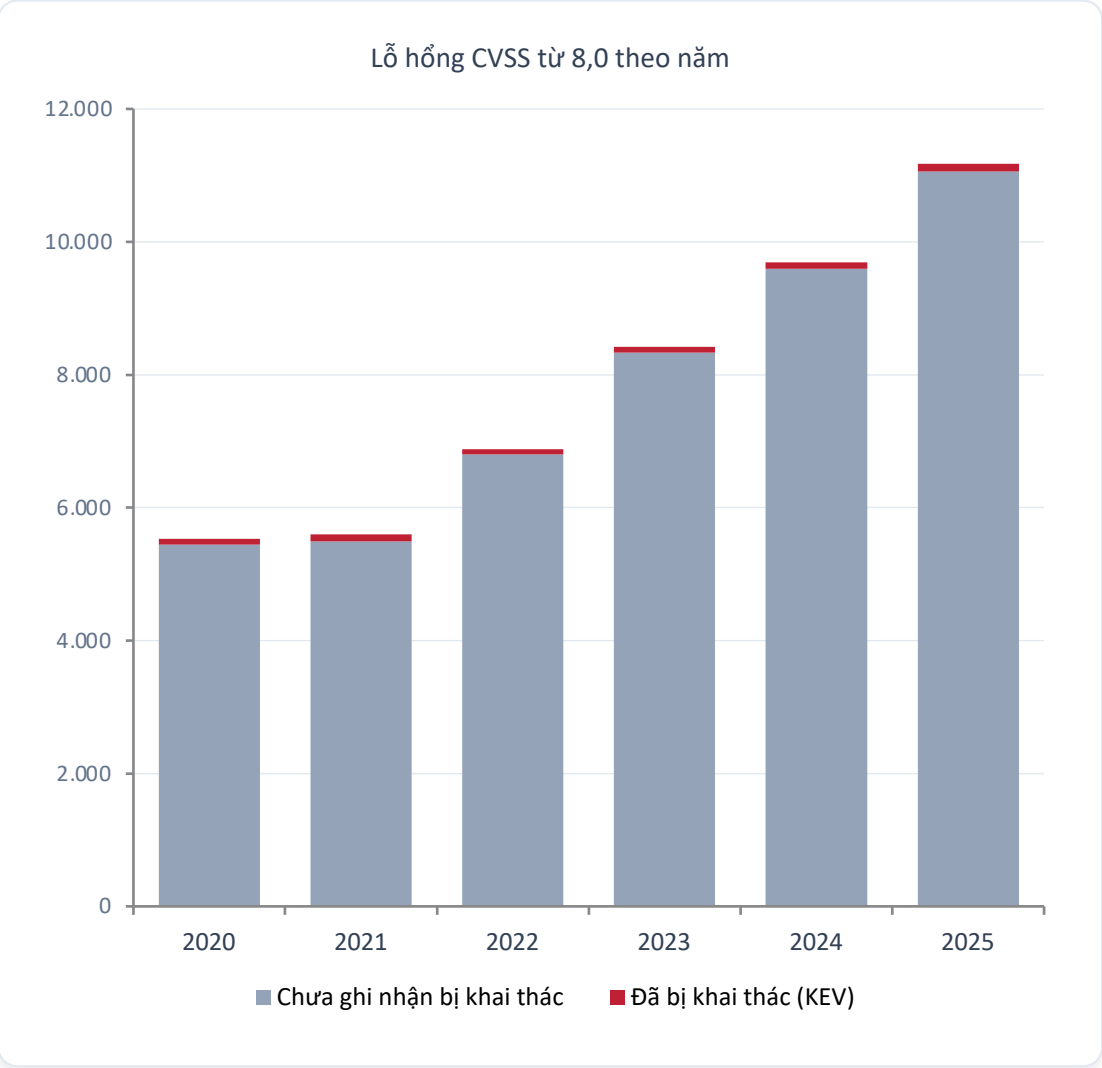
BA CÂU HỎI NGHIÊN CỨU

CH1 Quy tắc CVSS 8,0 vá thừa và bỏ sót bao nhiêu, kể cả khi đọc khuyến nghị sát hơn?

CH2 Công thức kết hợp CVSS, EPSS, KEV có ưu tiên tốt hơn khi chỉ dùng thông tin có tại thời điểm quyết định?

CH3 Công thức có khả thi khi triển khai và giới hạn của nó ở đâu?

98,69% lỗ hổng phải vá trong 48 giờ chưa từng bị khai thác



76,1

lỗ hổng phải vá mới trúng 1 lỗ hổng thực sự bị khai thác (giai đoạn 1999 đến 2025)

30,6 / ngày

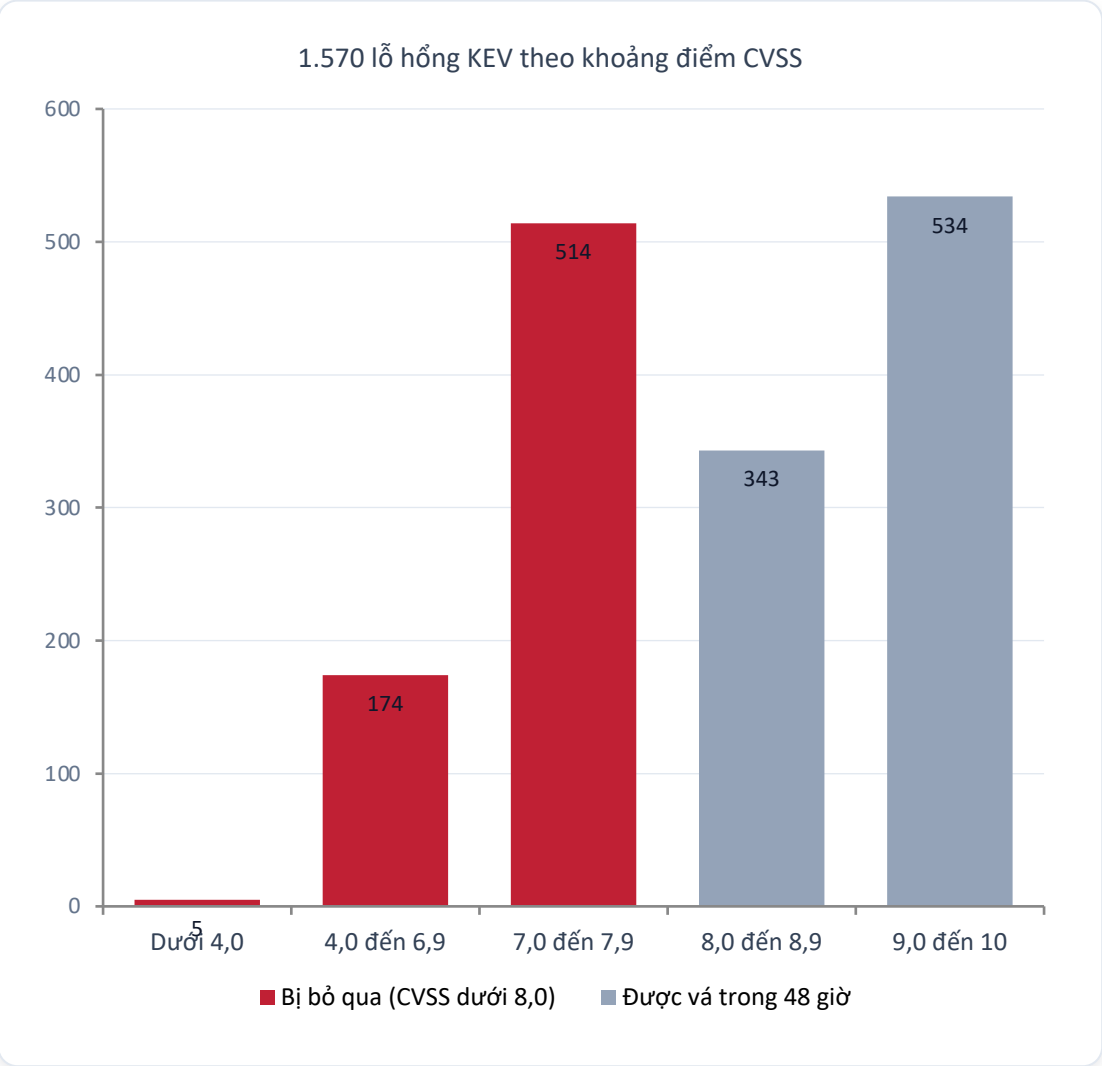
lỗ hổng CVSS từ 8,0 mới mỗi ngày năm 2025, gấp 2,0 lần năm 2020

1,02%

phần bị khai thác năm 2025 (114 / 11.170): khối lượng tăng, tỷ lệ trúng không tăng

Đội vận hành dồn sức cho lỗ hổng chưa bị tấn công.

44,14% lỗ hổng đã bị khai thác có CVSS dưới 8,0 nên bị quy tắc CSA bỏ qua



74,17%

lỗ hổng bị bỏ qua nằm sát ngưỡng, điểm 7,0 đến 7,9 (514 / 693)

42,27%

lỗ hổng KEV từng phục vụ mã độc tống tiền nằm trong nhóm bị bỏ qua (145 / 343)

39,4%

năm 2025 vẫn bị bỏ qua (74 / 188): vấn đề không giảm theo thời gian

Ngưỡng 8,0 cắt ngang vùng tập trung nhiều lỗ hổng bị khai thác.

Đọc sát khuyến nghị hay đổi ngưỡng chỉ chuyển gánh nặng giữa vá thừa và bỏ sót

Cách áp dụng quy tắc	Phải vá	Bỏ sót lỗ hổng KEV	Bị khai thác trong nhóm phải vá
CVSS từ 8,0 (cách đọc đơn giản)	27,75%	44,14%	**1,31%**
CVSS từ 8,0, chỉ lỗ hổng khai thác qua mạng (AV:N)	35,97%	26,25%	**1,34%**
Như trên, thêm điều kiện có PoC công khai	37,11%	20,73%	**1,40%**
Hạ ngưỡng xuống CVSS từ 7,0	54,33%	11,40%	**1,06%**
Nâng ngưỡng lên CVSS từ 9,0	14,43%	65,99%	**1,54%**

1,1% đến 1,5%

nhóm phải vá bị khai thác ở mọi cách áp dụng: vá thừa không đổi

HÀM Ý

Không có ngưỡng CVSS nào vừa giảm vá thừa vừa giảm bỏ sót: cần thêm thông tin về khai thác thực tế.

CISA đã bỏ hạn vá theo CVSS, chuyển sang bốn biến rủi ro trong BOD 26-04

BỐN CÂU HỎI CÓ HOẶC KHÔNG, CHO TỪNG LỖ HỔNG TRÊN TỪNG TÀI SẢN

Phơi ra Internet

Tài sản có truy cập được từ mạng công cộng?

Có trong KEV

Lỗ hổng đã bị khai thác thực tế?

Tự động hóa được

Kẻ tấn công tự động hóa được toàn bộ chuỗi khai thác?

Tác động kỹ thuật

Khai thác xong chiếm toàn quyền hay một phần?

HẠN VÁ THEO TỔ HỢP CÂU TRẢ LỜI (BẢNG 1 CỦA CHỈ THỊ)

3 ngày	3 ngày	14 ngày	60 ngày	Lần nâng cấp
kèm điều tra xâm nhập				hệ thống kế tiếp

Không còn yêu cầu dùng CVSS để xếp ưu tiên khi thu hồi BOD 19-02 (hướng dẫn thực hiện, 10/06/2026)

Chỉ 26% lỗ hổng KEV được khắc phục hoàn toàn năm 2025, giảm từ 38% (Verizon DBIR 2026, CISA dẫn trong blog)

Công thức S gộp năm nguồn thông tin thành một điểm ưu tiên từ 0 đến 100

$$S = AC \times CVSS \times [\, KEV \times PE + (1 - KEV) \times (\, EA \times PE + (1 - EA) \times EPSS^{0,3} \,) \,] \times 10$$

Phần trong ngoặc vuông là bộ lọc mối đe dọa T, nhận giá trị từ 0 đến 1

AC

Mức quan trọng của tài sản

0 đến 1, tổ chức tự xác định (CMDB)

CVSS

Mức nghiêm trọng kỹ thuật

0 đến 10, từ NVD

KEV

Đã bị khai thác thực tế

1 nếu có trong danh mục KEV

EA

Tự động hóa được (BOD 26-04)

1 nếu Automatable là Yes (Vulnrichment)

PE

Phơi ra Internet (BOD 26-04)

1 nếu tài sản truy cập được từ Internet

EPSS

Xác suất bị khai thác trong 30 ngày

0 đến 1, từ FIRST

Bộ lọc mối đe dọa tự rẽ năm nhánh mà không cần câu lệnh điều kiện

KEV	EA	PE	T	Ý nghĩa
1	0 hoặc 1	1	**1**	Đã bị khai thác, tiếp cận được từ Internet: mức cao nhất
1	0 hoặc 1	0	**0**	Đã bị khai thác nhưng nằm trong mạng nội bộ: hạ ưu tiên, xử lý bằng quy tắc chính sách
0	1	1	**1**	Tự động hóa được và phơi ra Internet: mức cao nhất, không chờ EPSS
0	1	0	**0**	Tự động hóa được nhưng công cụ quét từ Internet không nhìn thấy
0	0	0 hoặc 1	**$EPSS^{0,3}$**	Không tự động hóa được: điểm tăng dần theo EPSS, kể cả trong mạng nội bộ

VÌ SAO PE KHÔNG NHÂN VỚI EPSS

EPSS học từ tấn công toàn cầu, gồm cả thư lừa đảo, mối đe dọa nội bộ, VPN. Lỗ hổng trong mạng nội bộ vẫn có thể bị tấn công, nên không để về 0.

VÌ SAO SỐ MŨ 0,3

Phần lớn EPSS rất nhỏ. Số mũ nén thang mà giữ thứ tự: 0,001 thành 0,13; 0,01 thành 0,25; 0,1 thành 0,50. Thử từ 0,2 đến 1,0 cho kết quả gần như nhau.

Cùng CVSS 9,0: trên Internet được 90 điểm, trong mạng nội bộ còn 0

	CVSS	EPSS	KEV	EA	PE	Điểm S	Quy tắc CSA
A	9,8	0,001	0	0	1	**12,3**	Vá trong 48 giờ
B	7,5	0,90	0	0	1	**72,7**	Bỏ qua
C	6,5		1		1	**65,0**	Bỏ qua
D	9,0	0,10	0	1	1	**90,0**	Vá trong 48 giờ
E	9,0	0,10	0	1	0	**0,0**	Ngoài phạm vi
F	8,8		1		0	**0,0**	Ngoài phạm vi
G	7,8	0,30	0	0	0	**54,4**	Ngoài phạm vi

Số liệu giả định, AC = 1

ĐỌC VÍ DỤ

- D lên đầu vì tự động hóa được và phơi ra Internet; nếu EA = 0 chỉ còn 45,1
- B xếp thứ hai dù CSA bỏ qua: EPSS 0,90
- A chỉ 12,3 vì gần như không có tín hiệu khai thác
- C vào nhóm khẩn cấp nhờ quy tắc KEV dù điểm 65
- G nội bộ vẫn 54,4 nhờ EPSS

Kiểm thử ngược chỉ dùng thông tin có tại ngày đánh giá để không nhìn trước đáp án

1. Chọn ngày T

trong quá khứ, ví dụ 30/06/2025

2. Chấm điểm S

bằng EPSS và KEV có tại ngày T

3. Theo dõi 12 tháng

lỗ hổng nào thực sự vào KEV

4. So sánh

với CVSS, EPSS, quy tắc CSA khi cùng khối lượng vá

PHẠM VI ĐÃ KIỂM CHỨNG

$$S0 = AC \times CVSS \times [\, KEV + (1 - KEV) \times EPSS^{0,3} \,] \times 10$$

Dạng rút gọn khi PE = 1 (đúng phạm vi CSA) và EA = 0; thực nghiệm đặt AC = 1. EA, PE, AC chưa có dữ liệu công khai đủ để kiểm chứng.

QUY MÔ KIỂM CHỨNG

7

thực nghiệm, từ thống kê ngưỡng tới tình huống điển hình

11

ngày đánh giá cuối quý, 03/2023 đến 09/2025

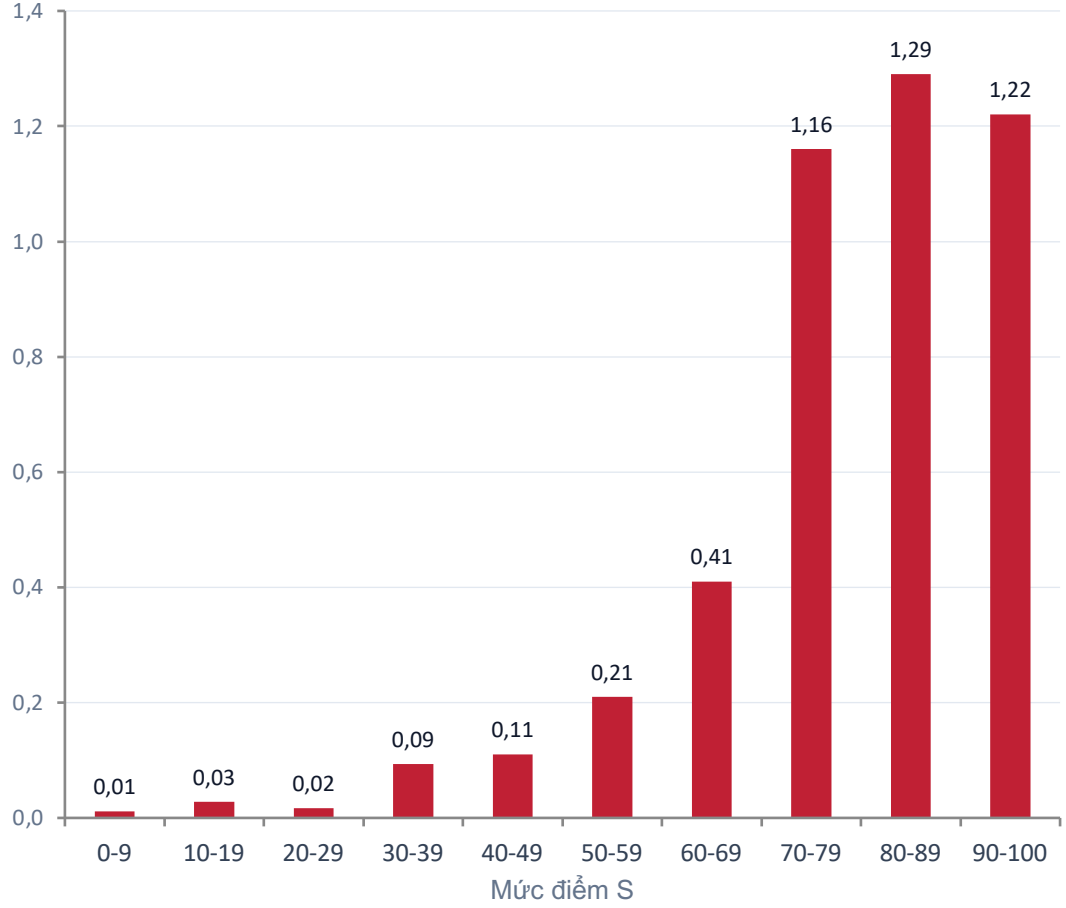
1.000

lần lấy mẫu bootstrap cho khoảng tin cậy 95%

836

lỗ hổng vào KEV từ 01/04/2023 cho phép thử trước KEV

Điểm S càng cao càng dễ bị khai thác: mức từ 70 gấp khoảng 28 lần trung bình



1,34%

số lỗ hổng chưa có trong KEV đạt S từ 70 (2.803 / 209.623)

37,36%

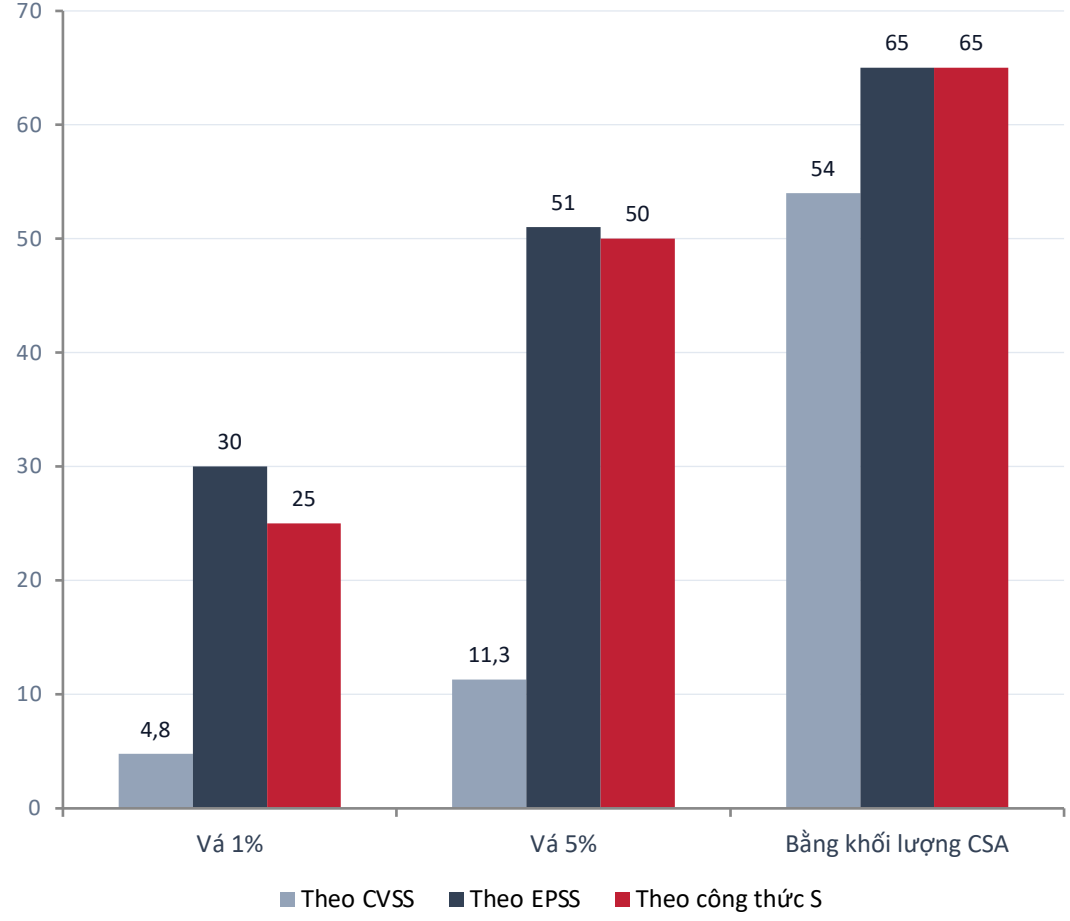
lỗ hổng sắp bị khai thác nằm trong nhóm này (34 / 91)

0,043%

tỷ lệ vào KEV trung bình của 209.623 lỗ hổng

Dưới 30 điểm: chỉ 0,01% đến 0,03%.

Khi chỉ vá 1% đến 5% số lỗ hổng, S bắt được nhiều gấp 2,7 đến 8,9 lần xếp theo CVSS



ĐÃ CHỨNG MINH

Vá 1% hoặc 5%: S hơn CVSS ở cả 11 ngày; khoảng tin cậy nằm hoàn toàn trên 0

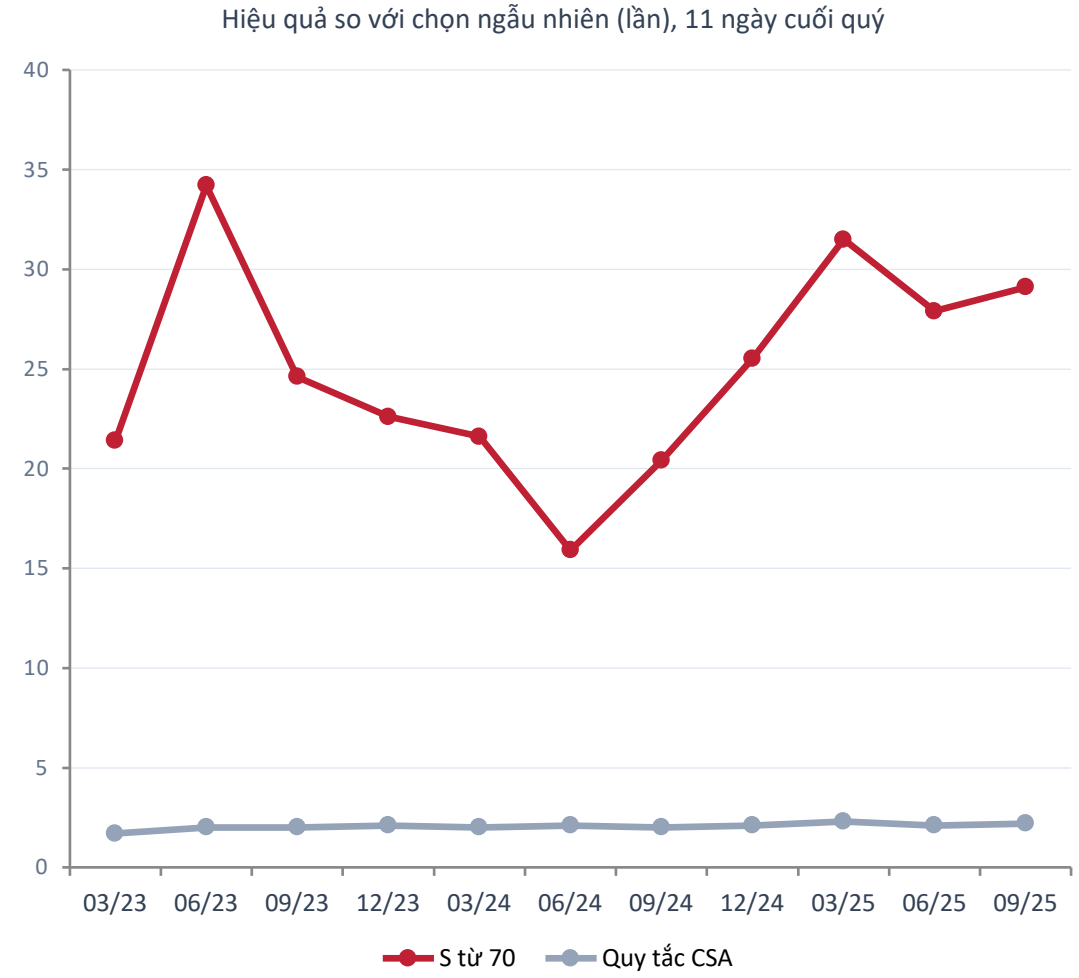
CHƯA ỔN ĐỊNH

Bằng khối lượng CSA: hơn CVSS 2 trên 3 ngày; giả thuyết H1 chưa đạt

SO VỚI EPSS

Gần như ngang; S thêm trọng số mức nghiêm trọng, không làm dự đoán tốt hơn

Ngưỡng S từ 70 hiệu quả gấp 16 đến 34 lần ngẫu nhiên, quy tắc CSA chỉ khoảng 2 lần



0,78% đến 1,40%

số lỗ hổng thuộc mức S từ 70 qua 11 ngày: khối lượng vá rất nhỏ

47,1% đến 47,8%

kết quả trung bình với mọi số mũ từ 0,2 đến 1,0: không phụ thuộc lựa chọn 0,3

Khối lượng mức 70 tăng từ 0,78% lên 1,40% khi EPSS đổi mô hình tháng 3/2025: ngưỡng cần hiệu chỉnh theo phiên bản EPSS.

S đưa 24 lỗ hổng KEV lên nhóm ưu tiên trước khi CISA xác nhận, CSA bỏ qua cả 24

CVE-2021-26086

Atlassian Jira, CVSS 5,3

S khoảng 50 liên tục từ 02/2024, 8 tháng trước khi vào KEV (12/11/2024)

CVE-2023-32315

Openfire, CVSS 7,5

S tăng 7, 34, 62 trong hai tháng sau công bố, gần 1 tháng trước khi vào KEV (24/08/2023)

CVE-2015-5477

ISC BIND, CVSS 7,5

S khoảng 73 liên tục từ 02/2022; CISA xác nhận ngày 08/10/2026, tức 55 tháng sau

24 / 156

lỗ hổng KEV có CVSS dưới 8,0 và có EPSS đạt S từ 50 vào 30 ngày trước khi vào KEV (15,38%)

ĐỌC ĐÚNG TÌNH HUỐNG

- Báo trước là trước khi CISA xác nhận, chưa chắc trước khi bị khai thác
- 12 / 24 lần vượt ngưỡng trùng tháng EPSS đổi mô hình
- 76,28% vẫn dưới 30 điểm trước khi vào KEV

Công thức chưa cảnh báo được lỗ hổng mới công bố, đúng nhóm CSA lo ngại nhất

27,15%

lỗ hổng vào KEV từ 01/04/2023 chưa có EPSS trước khi vào KEV (227 / 836): zero-day, chỉ thành phần KEV xử lý được

4,46%

lỗ hổng công bố tối đa 30 ngày trước khi vào KEV đạt S từ 70 một ngày trước đó (10 / 224)

22,9

điểm S cao nhất của CVE-2025-13956 khi CrowdSec ghi nhận bị khai thác: EPSS phản ứng chậm hơn dữ liệu tấn công trực tiếp

CHƯA KIỂM CHỨNG ĐƯỢC

- AC và PE: cần danh mục tài sản của tổ chức
- EA: Vulnrichment chỉ phủ khoảng 45,8% số CVE theo ước tính của Securin
- So với EPSS dùng riêng: chưa tốt hơn
- Căn cứ KEV chậm và nghiêng về sản phẩm phổ biến tại Mỹ

Với lỗ hổng mới, chính sách vẫn cần quy tắc KEV, cảnh báo nhà cung cấp và tình báo mối đe dọa.

Thay ngưỡng CVSS cố định bằng thang điểm S có hạn vá theo từng mức

Khẩn cấp	KEV hoặc tự động hóa được, trên tài sản phơi ra Internet	**3 ngày**
Nghiêm trọng	S từ 70 đến 100	**7 ngày**
Cao	S từ 50 đến 69	**14 ngày**
Trung bình	S từ 30 đến 49	**30 ngày**
Thấp	S từ 10 đến 29	**60 ngày**
Rất thấp	S từ 0 đến 9	**Lần nâng cấp kế tiếp**

Lỗ hổng KEV trên tài sản nội bộ: 14 ngày, hoặc 3 ngày kèm điều tra nếu tự động hóa được và chiếm toàn quyền (theo BOD 26-04)

Xét điều kiện khẩn cấp trước, xét điểm sau.

CĂN CỨ SỐ LIỆU

1,34%

khối lượng vá của mức Nghiêm trọng

37,36%

lỗ hổng sắp bị khai thác nằm trong mức này

Hạn 7, 14, 30, 60 ngày là đề xuất của nhóm, chưa kiểm chứng; hạn 3, 14, 60 ngày lấy theo BOD 26-04.

Kết hợp bằng chứng khai thác và mức nghiêm trọng vá đúng chỗ hơn CVSS

KẾT LUẬN

1. Ngưỡng CVSS 8,0 vá thừa 98,69% và bỏ sót 21% đến 44% lỗ hổng bị khai thác, tùy cách đọc

2. Công thức S hiệu quả hơn rõ rệt khi nguồn lực vá có hạn, ổn định qua 11 ngày đánh giá

3. Kết luận cùng hướng với BOD 26-04: bỏ CVSS làm căn cứ chính, đặt bằng chứng khai thác vào trung tâm

HƯỚNG PHÁT TRIỂN

- Kiểm chứng biến EA bằng dữ liệu Vulnrichment, xử lý rò rỉ dữ liệu tương lai
- Kiểm chứng PE và AC trên dữ liệu tài sản của một tổ chức thực
- Thêm tín hiệu sớm cho lỗ hổng mới: PoC, cảnh báo nhà cung cấp, dữ liệu tấn công trực tiếp

HUST

hust.edu.vn fb.com/dhbkhn

THANK YOU !

Nhóm 14, Chính sách và Quản trị an ninh mạng